

CHANGE MANAGEMENT POLICY

Version 1.0

Revision Date: August 18, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Change Management Policy
Document ID	POL-CM-001
Current Version	1.0
Approved Date	August 18, 2026
Approved By	Information Security Steering Committee
Effective Date	August 18, 2026
Next Review Date	August 18, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	N/A
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		August 18, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		August 18, 2026

COMPLIANCE

This Policy is authorized by the Information Security Policy (POL-ISP-001) and supports the SOC 2 Trust Services Criteria CC4.1, CC5.2 and CC8.1, and GDPR Article 32. It uses the Company's existing pull request workflow as the change process rather than adding one alongside it.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE	5
2 SCOPE	5
3 ROLES AND DEFINITIONS.....	5
4 TERMINOLOGY	5
5 HOW A CHANGE IS MADE.....	6
6 SECURITY ASSESSMENT	6
7 STANDARD, NORMAL AND EMERGENCY	7
8 EMERGENCY CHANGES	7
9 REVIEWING THE CHANGE POPULATION	7
10 RECORDS	7
11 EXCEPTIONS.....	8
12 REFERENCE	8
13 DOCUMENT POLICY HISTORY.....	8

1 Overview and Purpose

PromptHalo Technologies (“the Company”) ships changes through pull requests in GitHub and deploys through a pipeline. This Policy makes that the change process rather than describing a second one beside it.

Almost everything an auditor wants from change management — a record, a justification, an approver, a test, a traceable deployment — the pull request already produces. What this Policy adds is the small set of things it does not: which changes are in scope, what security assessment means, and what happens in an emergency.

2 Scope

This Policy covers changes to the systems in the audit boundary: application code, infrastructure as code, the AWS configuration those define, and the prompts, tool definitions, retrieval configuration, guardrails and model versions the Company runs.

It does not cover routine content edits with no effect on how a system behaves, or configuration the Cloud Platform Standard fixes as a baseline.

3 Roles and Definitions

1. "The Company" refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this policy, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this policy and reviews it at least annually. [SOC 2: CC1.2, CC5.3]
4. Anyone may propose a change. Approval comes from someone who is not its sole author. Where the Company genuinely has only one person able to review a change, the CEO records that fact and the compensating check applied, rather than the approval being skipped. [SOC 2: CC8.1, CC5.2]

4 Terminology

The following terms have the meanings given below wherever they appear in this policy.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this policy.
2. **Change** — a modification to a system in scope, including its configuration, prompts and model versions.
3. **Confidential information** — information classified Confidential or Restricted under the Data Classification Policy, including customer data.
4. **Control** — an activity, automated or manual, performed on a defined cadence that produces evidence it occurred.

5. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.
6. **Emergency change** — a change made to restore service or contain an incident, approved after the fact under Section 8.
7. **Information Security Steering Committee** — the Company's oversight body for information security. At the Company's current size, the Committee comprises the CEO, and every reference in this policy to a decision, approval, review or report of the Committee is satisfied by a dated written record made or confirmed by the CEO; a formal meeting is not required. [SOC 2: CC1.2, CC1.3]
8. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of the Company.
9. **Pipeline** — the automated route through which changes reach production.
10. **Security Officer** — the individual accountable for day-to-day operation of the security program.
11. **Significant change** — a change meeting the trigger criteria in the Risk Management Policy that requires risk reassessment.
12. **Standard change** — a change on the pre-approved list at Section 7, which needs no individual approval.
13. **Subservice organization** — a third party whose controls the Company relies upon and which is carved out of the Company's report.

5 How a Change Is Made

1. Every change in scope goes through a pull request that records what is changing, why, and who asked for it. The pull request is the change record; no separate change register is kept. [SOC 2: CC8.1]
2. Approval precedes implementation and comes from someone other than the sole author. Branch protection enforces this so it cannot be skipped by accident. [SOC 2: CC8.1]
3. Changes are tested before production. What testing means is proportionate to what is changing, and the evidence is the pipeline run attached to the pull request. [SOC 2: CC8.1]
4. Production is reached only through the pipeline. Direct console or manual changes to production are emergency changes and follow Section 8. [SOC 2: CC8.1, CC5.2]
5. Access to deploy is restricted to those whose role requires it, under the Access Control Policy. [SOC 2: CC5.2, CC6.3]

6 Security Assessment

1. Security impact is assessed at review, not as a separate gate. The reviewer considers whether the change affects who can reach what, how data is protected, what is logged, or what an agent can do — and says so in the pull request. [SOC 2: CC8.1]

2. Where a change touches prompts, tool definitions, retrieval configuration, guardrails or model versions, the check at Section 12 of the AI Governance Policy applies in addition, but only where that section says it does. [SOC 2: CC8.1]
3. A change that moves the system boundary is a significant change and triggers reassessment under the Risk Management Policy before it goes live. [SOC 2: CC8.1, CC3.4]

7 Standard, Normal and Emergency

1. Standard changes are pre-approved and need no individual approval: dependency updates that pass the pipeline, documentation, and configuration explicitly listed as standard. The list is maintained and reviewed once a year. [SOC 2: CC8.1]
2. Normal changes are everything else and follow Section 5. [SOC 2: CC8.1]
3. Adding to the standard list is itself a change and is approved as one. That is what stops the list quietly absorbing everything. [SOC 2: CC8.1]

8 Emergency / HotFixes / Changes

1. A change made to restore service or contain an incident may be implemented first. It is recorded the same day, approved after the fact by someone other than the person who made it, and reflected into code where it was made by hand. [SOC 2: CC8.1, CC7.4]
2. Emergency changes are looked at as a group at the six-monthly review below. A pattern of emergencies is a signal about the normal path, not about the emergencies. [SOC 2: CC8.1, CC4.1]

9 Reviewing the Change Population

1. A complete population of production deployments for any period is exportable from the pipeline, each traceable to an approved change. That export is the evidence; nothing needs to be assembled by hand. [SOC 2: CC8.1, CC2.1]
2. The population is reviewed every six months for changes with no approver, changes approved by their own author, deployments with no matching change record, and emergency changes never reconciled. Each finding gets a recorded disposition. [SOC 2: CC4.1, CC8.1]
3. Two reviews a year, each an export and a read-through. Where nothing anomalous appears, that is recorded and the review is complete. [SOC 2: CC4.1]

10 Records

1. Pull requests as change records, with approvals and pipeline runs. [SOC 2: CC8.1]
2. The exportable deployment population for any period. [SOC 2: CC8.1]
3. Two six-monthly change population reviews a year, with dispositions. [SOC 2: CC4.1]
4. The standard change list and its annual review. [SOC 2: CC8.1]
5. Emergency change records with after-the-fact approvals. [SOC 2: CC8.1]

11 Exceptions

Where a requirement of this Policy cannot be met — a change that genuinely has no second reviewer, or a platform without pipeline deployment — the position is recorded by the Accountable Party with the compensating measure and a review date. Where no exceptions are in force, that is recorded affirmatively at the annual review.

12 Reference

- SOC 2 Trust Services Criteria, Security category [CC4.1, CC5.2, CC8.1]
- POL-ISP-001 Information Security Policy [SOC 2: CC5.3]
- POL-AI-001 Artificial Intelligence Governance Policy [SOC 2: CC8.1]
- POL-AC-001 Access Control Policy [SOC 2: CC5.2, CC6.3]
- POL-RSK-001 Risk Management Policy [SOC 2: CC3.4]
- STD-CLD-001 Cloud Platform Standard [SOC 2: CC7.1]
- POL-SDLC-001 Secure Software Development Life Cycle Policy [SOC 2: CC8.1]
- EU General Data Protection Regulation, Article 32

13 Document Policy History

Version	Date	Description
1.0	August 18, 2026	Initial policy release